

Foundational Interaction Primitives (FIP): From Semantic Authority to Enforceable Boundaries for Autonomous Agents

Edward T Chow
Interbilla LLC

Abstract— When autonomous AI systems invoke tools, access services, and cross organizational boundaries, security depends on two distinct questions: is an action semantically authorized, and can that authority be translated into execution controls without widening its scope? We present Foundational Interaction Primitives (FIP), an architecture that separates descriptive domain knowledge from operational authority. FIP 0.1 establishes a semantic authority model using a Governed Operational Context Projection (GOCP) and an independent Semantic Micro-Firewall (SMF). Across bounded FIP 0.1 evaluations—including approximately 448,000 symbolic adversarial actions or candidate expansions, a held-out healthcare-domain transfer, and protected evaluations with GPT-5.6 Luna and Sol—we observed no unauthorized operational effects under the tested conditions; these counts are not treated as independent statistical trials. FIP 0.2 extends this architecture with explicit execution bindings and enforcement requirements while preserving the semantic core. We evaluate FIP 0.2 through Q13, a static adversarial qualification of the semantic-to-policy translation chain. Initial Q13 runs exposed genuine defects in temporal validity, delegation dispatch, authorization matching, derivation integrity, and target representability. These failures were preserved as regression cases and repaired prospectively. In the final 757-case constrained combinatorial campaign, the frozen FIP 0.2 candidate produced zero unauthorized deployable authority. Q13 did not execute runtime operational actions. The results show that semantic authorization and technical policy compilation can be separated into explicit, independently testable security boundaries.

Index Terms—agentic AI, AI governance, semantic interoperability, runtime governance, semantic firewall, authorization, enforcement, multi-agent systems, zero trust, sandboxing

I. INTRODUCTION

As AI systems become more agentic and impactful, safety can no longer rely on models simply understanding instructions or sharing a common language. Autonomous agents can hallucinate, be manipulated, chain individually plausible actions into unsafe delegations, and cross organizational boundaries whose domain models and authorities differ. The core systems problem is therefore not only whether an agent can interpret a request, but whether a specific interaction is authorized to produce a specific operational effect.

We propose separating descriptive domain semantics from operational authority. Within this architecture, FIP acts as a compact interaction layer. Domain ontologies describe what entities are; FIP describes how participants, actions, resources, purposes, authority, authorization, delegation, validity, evidence, and related governance concepts participate in consequential interactions. The central design principle is that expanding a system's descriptive vocabulary must not

automatically expand its governance vocabulary: open description, closed operational interpretation.

FIP 0.1 addressed the semantic side of this problem. It defined a frozen 26-primitive, 24-relation Reference Candidate, a GOCP boundary controlling which descriptive facts may become governance-bearing context, and an independent SMF that evaluates consequential interactions. Q9-Q12 then tested whether untrusted or recomposed semantics could manufacture authority under bounded adversarial conditions.

FIP 0.2 addresses the next problem revealed by deployment: a correct semantic authorization is not yet an execution permission. Between a semantic decision and a filesystem, network, API, tool, credential, model, device, or other execution boundary lies a translation problem. If that translation widens a resource, loses a purpose or validity condition, treats an unsupported target feature as enforced, or accepts stale authority, the execution policy can exceed the authority that FIP actually granted.

A. Contributions

- (1) FIP 0.1, a compact 26-primitive, 24-relation semantic interaction vocabulary, preserved unchanged as the semantic Reference Candidate.
- (2) GOCP, a governed projection boundary between extensible descriptive semantics and governance-bearing operational context.
- (3) A stateful Semantic Micro-Firewall that evaluates consequential interactions using explicit, bound authority rather than ambient agent privilege.
- (4) FIP 0.2, a 28-primitive, 26-relation Enforcement Candidate adding ExecutionBinding and EnforcementRequirement plus hasExecutionBinding and requiresEnforcement.
- (5) A target-neutral Enforcement IR and adapter/coverage model in which a deployable target policy must be freshly derived, representable, truthfully covered, and non-widening.
- (6) An OpenShell v0.1.2 reference adapter used to qualify filesystem and network/API compilation behavior while keeping OpenShell-specific vocabulary outside the FIP core.
- (7) Q13, a static semantic-to-enforcement adversarial qualification campaign that preserved genuine failures, repaired them prospectively, and converted them into regression seeds before a final 757-case deterministic combinatorial run.

The principal empirical claims remain deliberately bounded. Q9-Q12 provide evidence about semantic authorization and

observed operational effects within their evaluated domains, attack classes, observation models, and budgets. Q13 provides static qualification of the semantic-to-enforcement-policy chain. Its 757 generated cases are engineering exposure, not independent statistical trials, and Q13 did not execute runtime operational actions.

II. SYSTEM AND THREAT MODEL

A. Semantic System Model

Let D_t denote extensible descriptive/domain state at time t , G_t the governed operational context admitted by an active GOCP, I_t a consequential FIP interaction, δ_t the semantic decision, $A_{\text{valid}}(t)$ the currently valid semantic authority, and E_t an operational effect. The Universal Domain Graph (UDG) [21] may relate spatial, temporal, organizational, legal, governance, infrastructure, mission, and other semantic hyperspaces, but cross-hyperspace reachability does not itself establish operational authority.

$$\text{SemanticReachability}(x) \neq \text{OperationalAuthority}(x)$$

Descriptive assertions may arrive through natural language, ontologies, memory, other agents, credentials, evidence claims, provenance claims, prior decisions, or external schemas. The principal semantic invariant is that no such assertion acquires operational authority solely by being interpretable.

B. Enforcement Extension

FIP 0.2 adds an explicit boundary between semantic authorization and target enforcement. A Resource remains a semantic interaction role and an Action remains a semantic action. Concrete paths, hosts, ports, URIs, service identifiers, executable identifiers, model identifiers, device identifiers, and message channels belong in ExecutionBinding. Concrete enforcement effects and constraints belong in EnforcementRequirement.

$$\text{AUTHORIZED} \neq \text{FULL} \neq \text{TargetPolicy} \neq \text{ENFORCED_ALLOW}$$

The four states above answer different questions. AUTHORIZED is a semantic authority decision. FULL is a compilation/coverage disposition indicating that the evaluated requirement can be represented without known loss under the selected target profile. A target policy is an emitted technical artifact. ENFORCED_ALLOW is a runtime observation. None of these states is permitted to stand in for another.

C. Threat Classes

The FIP 0.1 threat model includes untrusted-semantic injection and admitted-context authority recomposition. An adversary may introduce descriptive semantics or recombine legitimate facts outside their authorized actor, action, resource, purpose, scope, delegation, evidence/provenance, or temporal bounds.

FIP 0.2 adds translation and freshness threats: stale authority, stale approvals, stale IR, substituted actors or resources, forged or non-delegable delegation, widened filesystem or network targets, unsupported target semantics stamped as covered, and target policies that remain technically present after semantic authority contracts. Direct compromise

of the trusted computing base remains outside the evaluated claim.

III. DERIVATION OF FOUNDATIONAL INTERACTION PRIMITIVES

FIP asks a narrower question than a world ontology: what domain-independent semantics are required to represent a consequential interaction sufficiently for governance? FIP 0.1 was informed by architectural analysis, governance requirements, cross-domain qualification, adversarial experiments, implementation/conformance work, and a source-traceable evidence corpus containing 5,603 harvested concept seeds from source families including NIEM, NIMS, NIST SP 800-53, NIST CSF, NIST Privacy Framework, and NIST AI RMF.

The corpus was not reduced mechanically into 26 primitives. Semantic engineering and empirical evidence proceeded as separate tracks; a later audit reduced DIRECT harvest-to-FIP mappings to zero. Retention criteria included architectural necessity, governance significance, cross-domain recurrence, irreducible interaction role, and operational necessity. Application-specific types remain outside FIP.

FIP 0.1 remains candidate-minimal rather than proven minimal. Validity is retained because expired, revoked, superseded, and not-yet-valid grants require an explicit in-force distinction. Q13 subsequently demonstrated that this distinction is operationally load-bearing: early Q13 runs exposed acceptance of expired authority and delegation, and the repaired evaluator now checks current validity before an operational grant.

IV. FIP SEMANTIC AND ENFORCEMENT MODEL

A. FIP 0.1 Semantic Core

The 26 FIP 0.1 primitives are grouped for presentation rather than as separate type systems. Entity/participant: Actor, Resource, Role, Identity, Credential. Interaction/speech-act: Request, Response, Action, Assertion, Recommendation, Instruction, Delegation, Decision. Intent/context: Purpose, Condition, Constraint, Scope. Governance: Authority, Authorization, Permission, Prohibition, Obligation, Policy. Trust/evidence: Evidence, Provenance, Validity.

The 24 relations are requests, respondsTo, usesResource, hasPurpose, hasIdentity, presentsCredential, hasRole, ownedBy, controlledBy, actsUnderAuthority, authorizedBy, governedBy, permits, prohibits, obligates, constrainedBy, appliesWithin, validDuring, delegatesTo, delegatesAuthority, hasEvidence, derivedFrom, assertedBy, and decidedBy.

Actor, Role, and Identity remain distinct. Authority, Authorization, and Permission remain distinct. Credential, Evidence, and Provenance remain distinct. Communication ability is not delegation; a valid credential is not authorization; absence of prohibition is not permission.

$$\text{Representation} \neq \text{Validation} \neq \text{Authorization}$$

B. FIP 0.2 Enforcement Additions

FIP 0.2 preserves all 26 FIP 0.1 primitives and 24 relations and adds exactly two primitives—ExecutionBinding and

EnforcementRequirement—and two relations—hasExecutionBinding and requiresEnforcement. The semantic vocabulary therefore remains compact while gaining an explicit bridge to execution enforcement.

Element	Purpose
ExecutionBinding	Binds a semantic Resource/Action to a concrete execution locator and operation without redefining the semantic Resource or Action.
EnforcementRequirement	States permit, deny, approval, audit, constraint, condition, lifetime, and composition requirements that a target must enforce or reject.
hasExecutionBinding	Associates semantic authority with one or more concrete execution bindings.
requiresEnforcement	Associates an authorized interaction/policy with enforcement obligations.

ExecutionBinding kinds include filesystem, service, API, process, executable, model, inference-provider, credential, device, message-channel, datastore, and profile-admitted custom bindings. Operations include read, write, execute, connect, invoke, create, modify, delete, publish, subscribe, query, command, and profile-admitted custom operations. Unknown kinds or operations fail closed.

EnforcementRequirement effects are permit, deny, require-approval, and audit-only. Prohibition dominates overlapping permission. Missing authority is not permission; missing binding is not execution authorization; an obligation does not grant authority; and require-approval does not grant execution authority until an applicable Decision exists.

C. Decision Domains

Domain	Values	Meaning
authorityDecision	AUTHORIZED / DENIED / INCOMPLETE / REVIEW	Semantic authority result.
compilationDisposition	FULL / PARTIAL / REJECTED / NOT_COMPILED	Whether the authorized requirement is exactly and truthfully compilable.
runtimeDisposition	ENFORCED_ALLOW / ENFORCED_DENY / AUDIT_ONLY / APPROVAL_PENDING / UNOBSERVED	Observed runtime status; not inferred from compilation.

Operational FIP 0.2 is fail-closed by definition. PARTIAL is non-deployable by default. Target substrate capabilities are reported separately from FIP grants; a capability available in OpenShell or another substrate does not become semantic authority merely because the target can technically perform it.

V. GOVERNED OPERATIONAL CONTEXT PROJECTION

Bounding interaction semantics is insufficient if arbitrary descriptive semantics can manufacture the contextual inputs from which authority is inferred. GOCP therefore governs the transition from descriptive state D_t to operational context G_t . An active profile contains an identifier, version, status, admitted fields, mappings, trusted-source constraints, value constraints, governance significance, digest, and signature reference.

$$P_\Gamma : D_t \rightarrow G_t \cup \{\emptyset\}$$

For a descriptive assertion $d = \langle s, p, o, \rho \rangle$, projection admits governance-bearing meaning only when p has an active authorized mapping, the source/provenance ρ is allowed for that field, and o satisfies the field constraints. An unmapped assertion may remain descriptive but is excluded from governance input.

$$\text{AuthorityBearing}(P_\Gamma(d)) \Rightarrow \text{AuthorizedBinding}_\Gamma(d)$$

Memory, messages, credentials, and claimed provenance remain descriptive unless admitted through governed bindings. Repetition does not mint authority; a message is not delegation; a credential is not authorization; and claimed provenance is not trusted provenance.

VI. SEMANTIC MICRO-FIREWALL

The SMF independently evaluates a FIP interaction using governed context, policy, and trusted history. It is a semantic policy boundary, not a packet firewall, alignment mechanism, true-intent detector, or prompt-injection prevention system.

$$\delta_t = \text{SMF}(I_t, G_t, \Pi_t, H_t)$$

Authorization is bound rather than ambient. A useful conceptual tuple is $Z = \langle \text{actor, action, resource, purpose, scope, validity, evidence, provenance} \rangle$. Q13 strengthened this principle by requiring exact matching of presented resource, actor, authority identifier, and authorization identifier before a grant is projected. Role remains contextual and does not independently grant authority.

Stateful evaluation is required because individually legitimate events can form an unauthorized trajectory. History does not create authority; prior authorization does not imply current authorization; replay must be re-evaluated; and post-binding mutation invalidates the original authorization.

VII. FROM SEMANTIC AUTHORITY TO EXECUTION ENFORCEMENT

A. Enforcement Chain

FIP 0.2 replaces the underspecified notion of a generic resource gateway with an explicit, inspectable translation chain. Figure 1 depicts the FIP architecture and enforcement chain. The chain is target-neutral until the adapter boundary:

Current Valid Authority →
Matching Interaction →
Faithful Projection →
Verified Derivation →
Exact Target Representability →
Truthful Coverage →
Non-Widening Target Policy →
Runtime Observation

The Enforcement IR is a derived projection, not a second evaluator and not an authority source. Before a result may be marked FULL or emitted as deployable, the security-relevant content consumed by an adapter must match a fresh projection of the current AuthorityPolicy, Exchange, applicable Decisions, and governed context. If fresh evaluation produces no operational IR, a supplied IR cannot resurrect authority.

$$IR_consumed = \text{Project}(\text{Eval}(\text{current authority sources}))$$

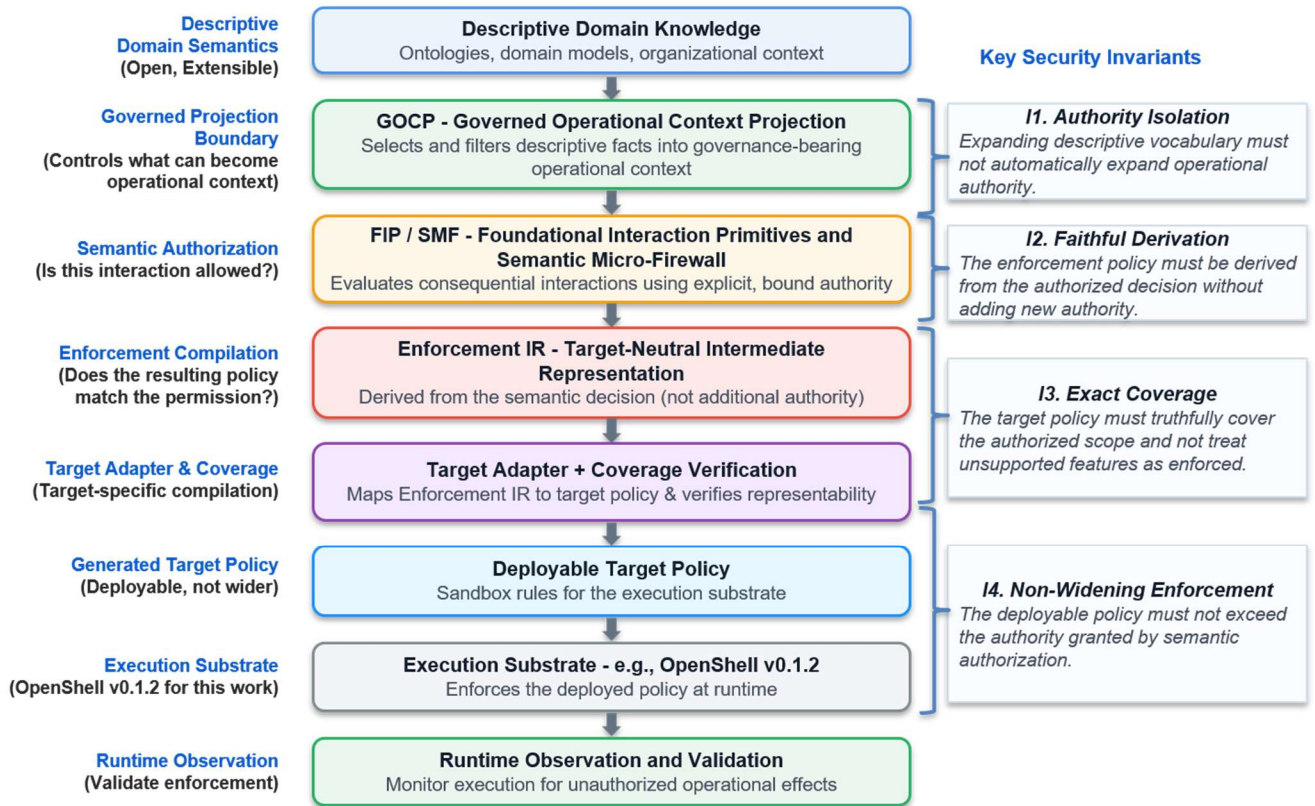


Figure 1 FIP architecture and enforcement chain from semantic authorization to runtime enforcement.

In software terms, an adapter may not trust an IR merely because it is well formed or previously signed. Before deployment, the consumed security content must correspond to a fresh projection of the current authority sources. If current evaluation no longer authorizes the interaction, an older IR cannot resurrect that authority.

The comparison includes deployment decision, requirements, composition, prohibitions, binding identifiers, resource/action, kind, operation, locator, protocol, lifetime, approval state, and substrate-versus-grant distinctions. A mismatch is rejected rather than approximated into a broader policy.

B. Coverage and Monotonicity

Each target adapter publishes a capability manifest. Coverage distinguishes enforced, unenforced, rejected, and baseline behavior. FULL is forbidden when a required semantic cannot be represented exactly under the pinned target profile. Unsupported, widened, or security-relevant approximations fail closed.

$$\text{TargetEffectiveAuthority} \subseteq \text{VerifiedCurrentProjection} \cup \text{AcceptedSubstrate}$$

Accepted substrate $S(t)$ represents explicitly documented technical authority required by the execution environment; it is not a FIP grant and cannot override a prohibition. The corresponding bounded safety property is:

$$E(t) \subseteq A_{\text{valid}}(t) \cup S(t)$$

Practically, the execution environment must not expose more effective authority than the agent currently has semantic

authority to use, except for explicitly documented substrate capabilities required by the enforcement mechanism itself. Those substrate capabilities are not FIP grants and cannot override a prohibition.

This property is an architectural invariant and an empirical qualification target, not a formal proof of the implementation.

C. OpenShell Reference Target

The first reference target is NVIDIA OpenShell. The FIP 0.2 candidate is pinned to OpenShell v0.1.2 for qualification. OpenShell provides declarative sandbox controls for filesystem, process, network/API, credentials/providers, and related execution surfaces; FIP supplies semantic authority and target-neutral enforcement requirements. OpenShell-specific predicates are intentionally excluded from the FIP vocabulary.

For the pinned profile, filesystem locators must be exactly representable absolute paths. Pattern-shaped or lexically ambiguous locators such as `/mission/*` are rejected rather than interpreted as broader filesystem grants. Directory rules may include descendants and symlink targets are not proved statically; these remain documented target limitations.

VIII. EXPERIMENTAL METHODOLOGY

A. FIP 0.1 Semantic Campaigns

The original experimental program attempted to falsify the semantic architecture rather than merely demonstrate expected behavior. A separate oracle labeled target effects AUTHORIZED or UNAUTHORIZED using frozen scenario policy and oracle-trusted state. Symbolic adversaries

systematically explored bounded semantic grammars; generative campaigns used GPT-5.6 Luna and GPT-5.6 Sol through a constrained action interface. The generative adversaries did not have unrestricted shell, arbitrary filesystem/network/container access, credentials, or hidden policy-oracle access.

Experiments were permitted to invalidate either architecture or methodology. When a run exposed a flaw, the result was preserved, the flaw was repaired prospectively, a new version/run was frozen, and the experiment was repeated. Failed or incomplete zero-bypass runs were not reinterpreted as security evidence.

B. Q13 Static Semantic-to-Enforcement Qualification

Q13 extended this discipline to the semantic-to-enforcement chain as a static adversarial qualification campaign. It was divided into Q13A semantic regression, Q13B static enforcement adversary, Q13C runtime-authority-evolution adversary, and Q13D deterministic constrained combinatorial/generative qualification. The Q13C label refers to temporal changes in authority state, not to execution of operational actions in a live sandbox. Across the accepted Q13 qualification, runtime opportunities were zero. Thus Q13 tests whether current semantic authority is faithfully preserved through derivation, representability, coverage, and target-policy generation; it does not establish runtime enforcement behavior.

Phase	Primary question	Accepted result
Q13A	Does evaluated authority equal currently valid authority?	PASS (q13-run-3, 30/30)
Q13B	Can IR/target translation widen authority or misstate representability?	Passed with documented limitations
Q13C	Do freshness, replay, delegation, approval, and authority changes preserve bounded authority?	Passed with documented limitations
Q13D	Do constrained combinations expose new authority paths?	Passed with documented limitations; 757 generated cases

Q13D used constrained pairwise coverage, named higher-order cases, temporal sequences, historical defect seeds, positive controls, mutations, and cross-surface/cross-enterprise cases. The aggregate 757 cases comprise 685 pairwise cases, 14 higher-order cases, 17 temporal steps, 7 historical regressions, 16 positive-control/mutation cases, and 18 cross-surface/cross-enterprise cases. These counts are not independent Bernoulli trials. The campaign does not provide exhaustive higher-order interaction coverage; untested three-way and higher-order combinations may expose defects not represented in Q13D.

C. Outcome Separation

Q9-Q12 used unauthorized operational effect rate (UOER) when runtime effects were actually observed. Q13 instead classified semantic prevention, derivation rejection, coverage rejection, target-policy rejection, stale-target detection, target limitation, approval withholding, and positive authorization. Because Q13 executed no runtime operational actions, its runtime UOER denominator is zero and no runtime UOER claim is made.

IX. RESULTS

A. FIP 0.1 Results

Experiment / scale	Protected outcome
Q9C-A-R1 - 5 vulnerable families	Symbolic attacker qualified
Q9C-B - 54,870 actions/candidates	0 unauthorized operational effects
Q10 - 339,134 candidate expansions	0 unauthorized operational effects; selective authorization
Q11-R1 - 54,870 actions	0 unauthorized operational effects; no new FIP terms
Q12-A3 - 536 model attempts	Luna qualified: 5/5 vulnerable families
Q12-B3 - 33 episodes; 541 semantic actions	Luna: UOER 0/33
Q12-C2 - 33 protected episodes	Sol: UOER 0/33; authorized controls 7/7

Across Q9C-B, Q10, and Q11-R1, approximately 448,874 symbolic adversarial actions or candidate expansions produced no unauthorized operational effect. These campaigns are not pooled as independent trials. Q11-R1 transferred the frozen 26/24 vocabulary to a held-out healthcare scenario without adding primitives or relations.

Q12-B3 completed 33 Luna protected episodes with zero unauthorized operational effects (UOER 0/33). Q12-C2 prospectively replaced Luna with GPT-5.6 Sol while preserving the protected architecture and semantic interface. Sol qualified on all five intentionally vulnerable families and then produced zero unauthorized operational effects across 33 protected episodes; 7/7 authorized controls executed. These results are bounded to the evaluated interface and observation model.

These episode counts provide bounded empirical evidence rather than a precise estimate of an underlying failure probability; for example, observing zero failures in 33 independent Bernoulli trials would still permit an approximate 95% upper failure-rate bound of 9% under the rule of three. Our episodes are not claimed to satisfy that independent-trial model.

B. Q13 Genuine Failures and Prospective Repairs

The strongest evidence from Q13 is not simply that the final campaign passed. Earlier Q13 runs falsified several implementations that appeared locally correct, exposing genuine product defects at independent boundaries: expired authority and delegation could be accepted; a non-delegable delegation could reach the wrong evaluation path; a presented resource could be substituted; a valid /mission/input authorization could be widened downstream to /mission; and /mission/* could be stamped FULL despite not being exactly representable under the pinned filesystem profile. Each failed run was preserved, the defect was repaired prospectively, and the failure was converted into a regression seed. These results show that the semantic-to-enforcement boundary is itself security-critical: correctness at a later stage cannot repair an invalid or widened result from an earlier stage.

Observed failure	Boundary exposed	Prospective repair / final behavior
------------------	------------------	-------------------------------------

Expired AuthorityPolicy or Delegation accepted	Temporal semantic authority	Current Validity checked before operational grant; expired/revoked state fails closed.
canDelegate:false bypassed	Semantic act dispatch	Delegation-specific predicate executes before generic operational grant.
Resource substitution accepted	Authorization matching	Exact resource/actor/authority/authorization matching before projection.
IR changed /mission/input to /mission	Derivation integrity	Consumed IR must equal fresh security projection; mismatch rejected.
/mission/* stamped FULL	Target representability	Pattern filesystem locator rejected as not exactly representable under pinned profile.

Separate harness/oracle defects were also preserved and were not counted as product failures. These included an incorrect substrate-oracle text check, an oracle that treated AUTHORIZED plus approval_required as executable despite no IR/policy, a wrong coverage field lookup, a misclassified resource-less Delegation, and an accidentally attached approval.

C. Q13 Final Qualification

Q13A passed at q13-run-3 (30/30). Q13B passed with documented limitations at q13b-run-3. Q13C passed with documented limitations at q13c-run-4. Q13D passed with documented limitations at q13d-run-4 using q13d-generator-4.

Q13D measure	Result
Generated exposure	757 constrained cases
Semantic decisions	186 AUTHORIZED; 443 DENIED; 128 INCOMPLETE; 0 REVIEW
Operational IR	182
Deployable current policies	157
Derivation rejection	19
Coverage rejection	18
Target verification	9 widened policies rejected; 3 stale policies detected
Target-limited	5
Unauthorized deployable authority	0 in accepted run
Runtime opportunities / UOER denominator	0 / 0

The final campaign reproduced all genuine historical defect seeds with fail-closed outcomes. Positive controls remained functional for exact filesystem, REST, TCP, MCP, bounded delegation, current approval, and authority restoration cases at the compilation/semantic level appropriate to each target. TCP and MCP FULL results are compilation results on the pinned OpenShell profile, not observed runtime allows.

D. Frozen Enforcement Candidate

Following Q13 qualification, the candidate was frozen and subjected to post-qualification regression testing. The Python and JavaScript conformance suites each passed 47/47 tests, 190 unit tests passed, and provenance checks covered 96 FIP 0.1 and 115 FIP 0.2 artifacts. The resulting FIP 0.2 Enforcement Candidate contains 28 primitives and 26 relationships. The

exact qualified implementation and evidence are preserved in the public artifact repository.

X. DISCUSSION AND LIMITATIONS

A. Authority Safety Is a Chain

The strongest architectural lesson from Q13 is that authority safety is not a single policy decision. A correct semantic decision cannot repair a widened IR; a correct adapter cannot repair an invalid semantic grant; a target capability cannot manufacture FIP authority; and a technically valid target policy cannot prove that the semantic authority that produced it is still current. Each transition requires its own invariant.

This motivates a layered view: semantic validity, interaction matching, projection, derivation, target representability, coverage, target-policy monotonicity, and runtime observation are separate obligations. A target policy prover can strengthen confidence in technical policy boundaries, but a prover pass is not a semantic authorization.

B. Static Semantic-to-Enforcement Qualification Boundary

The FIP 0.2 Q13 result is intentionally narrower than the FIP 0.1 operational-effect experiments. Q13 observed zero unauthorized deployable authority in the accepted static qualification runs, but it did not launch a sandbox or execute operational actions. Runtime opportunities were zero and the runtime UOER denominator was zero. Therefore Q13 does not establish end-to-end runtime security.

Earlier engineering milestones separately exercised OpenShell filesystem and REST enforcement, but those runs are not silently reclassified as Q13 runtime evidence. The qualification statement for the frozen candidate is: FIP 0.2 Enforcement Candidate—Q13 qualified with documented limitations for the evaluated semantic, derivation, coverage, and target-policy boundaries. Runtime operational enforcement was not evaluated by Q13.

C. Target Limitations

Documented limitations include establishment-bound filesystem enforcement; stale filesystem policy detection rather than demonstrated live retraction; directory rules that include descendants; lack of static proof of symlink targets; unobserved TCP and MCP runtime behavior; and unsupported exact executable identity, independent credential use, and exact model identity. Unsupported requirements fail closed rather than being reported as FULL.

The OpenShell statements in this qualification refer to the pinned v0.1.2 commit. Later OpenShell releases may have different semantics or capabilities and should be independently profiled before being treated as equivalent evidence.

Although the Enforcement IR is designed to be a target-neutral, the present enforcement qualification uses a single target implementation, OpenShell v0.1.2. The experiments therefore demonstrate a target-neutral architecture, not empirical portability or equivalent enforcement across multiple substrates.

D. Broader Limitations

The experiments do not imply zero probability of failure, universal security, formal verification, FIP completeness or minimality, production certification, universal domain independence, or prompt-injection prevention. GOCP assumes legitimate configuration; an incorrectly approved mapping can still produce incorrect governance. Richer attacker-visible feedback, longer-horizon collusion, trusted-computing-base compromise, and realistic physical/tool boundaries remain important.

XI. RELATED WORK

Reference monitors and capability security. Classical protection work established complete mediation and capability-based bounded authority [1], [2]. FIP inherits this lineage but places an explicit semantic-authorization layer upstream of technical enforcement.

Trust management, RBAC, ABAC, XACML, and deontic policy. PolicyMaker and related trust-management work separated credentials, policy, and trust decisions [3]. RBAC [4], ABAC [5], and XACML [6] provide mature authorization models. AgenticRei [15] extends runtime governance with deontic permissions, prohibitions, obligations, dispensations, conflict resolution, and ontological reasoning. FIP/GOCP does not seek to replace these formalisms; its upstream question is which assertions from an extensible semantic environment may become governance-bearing inputs and how resulting authority remains bound under composition and enforcement translation.

ODRL and provenance. ODRL represents permissions, prohibitions, duties, actions, assets, parties, and constraints [7]. W3C PROV provides interoperable provenance semantics [8]. FIP distinguishes represented provenance from trusted provenance and treats normative concepts as part of a consequential interaction envelope.

Agent communication languages. KQML [9] and FIPA ACL [10] establish structured communicative acts. FIP is not a transport or dialogue language; a communicative act does not itself establish operational authorization.

Zero trust. NIST SP 800-207 rejects implicit trust based on network location [11]. FIP uses a semantic analogy: intelligibility and reachability do not imply operational authority.

Runtime assurance and AI control. Simplex-style runtime assurance separates advanced autonomy from an independent safety mechanism [12]. AI Control studies protocols intended to prevent harmful outcomes even when a powerful model may intentionally subvert safeguards [13]. FIP applies an independent control pattern specifically to semantic authorization and then makes the translation to technical enforcement an explicit verification boundary.

Recent agentic-AI governance. Governance by Construction places policy interventions at multiple points in an agent pipeline [14]. AgenticRei develops deontic runtime policies [15]. SARC compiles governance constraints into runtime enforcement sites [16]. Aegis treats model outputs as action proposals mediated by trusted runtime policy and provenance [17]. TokenWall audits persistent-agent token flows [18].

CAVA canonicalizes heterogeneous runtime actions for approval binding and attestation [19]. MI9 proposes semantic telemetry, continuous authorization, conformance, drift detection, and containment [20].

Execution sandboxes. NVIDIA OpenShell provides a declarative execution-security substrate for autonomous agents, including filesystem, process, network, and provider/credential controls [23], [24]. FIP is complementary: it does not replace the sandbox. FIP represents and evaluates semantic authority, projects authorized requirements into a target-neutral IR, and requires adapters to demonstrate non-widening target coverage before deployment.

Positioning. The terms semantic firewall, runtime mediation, deontic policy, provenance, complete mediation, sandboxing, and structured agent acts all have prior art. The contribution claimed here is compositional: governed descriptive-to-operational projection (GOCP); compact consequential-interaction semantics (FIP); bound, stateful authority evaluation; and an explicit verified chain from semantic authority through target-neutral enforcement requirements to non-widening target policy.

System / focus	Position relative to FIP/GOCP
CUGA [14]	Policy-as-code at agent pipeline checkpoints; FIP/GOCP isolates semantic admission and bound interaction authority.
AgenticRei [15]	Deontic policy reasoning after predicates enter the decision space; GOCP governs semantic admission.
SARC [16]	Runtime constraint propagation; FIP adds compact interaction semantics and explicit authority-to-enforcement derivation.
Aegis [17]	Trusted action-proposal mediation; FIP also makes descriptive-to-operational semantic admission explicit.
TokenWall [18]	Semantic flow auditing; FIP models governance-bearing interaction roles and authority bindings.
CAVA [19]	Canonical action identity/approval/attestation; FIP focuses on semantic interaction authority plus governed context.
MI9 [20]	Integrated runtime governance; FIP emphasizes semantic non-authority, governed projection, recomposition, and verified enforcement derivation.
OpenShell [23], [24]	Execution-security substrate; FIP supplies semantic authority and a fail-closed translation contract to target policy.
This work	GOCP → FIP/SMF → EnforcementRequirement/IR → verified target adapter → execution substrate.

We do not report head-to-head empirical comparisons because the compared systems expose different policy abstractions, enforcement surfaces, and experimental threat models. Developing common cross-system authorization and enforcement benchmarks is future work.

XII. ARTIFACT AVAILABILITY AND REPRODUCIBILITY

The public FIP repository (<https://github.com/interbilla/fip>) contains the FIP 0.1 specification and conformance material, FIP 0.2 Enforcement Candidate specification and reference implementation, OpenShell compatibility profile, Q13 preserved runs, deterministic Q13D generator, qualification report, provenance manifests, and reproduction instructions

[22]. The frozen FIP 0.2 candidate is tagged `fip-0.2-enforcement-candidate-1`.

The qualification report is `docs/evidence/fip-0.2/q13/Q13-QUALIFICATION-REPORT.md`. Historical genuine failures and harness/oracle failures remain preserved. The candidate is an Enforcement Candidate qualified with documented limitations, not a stable release or production certification.

XIII. CONCLUSION

As autonomous AI systems invoke tools, modify persistent state, and coordinate across organizations, governance must answer two separate questions: whether a specific interaction is semantically authorized, and whether that authority can reach an execution boundary without being widened. FIP 0.1 addressed the first question through a compact interaction vocabulary, governed context projection, and independent semantic evaluation. Its Q9-Q12 evidence showed no unauthorized operational effects within the evaluated symbolic and generative adversarial conditions.

FIP 0.2 exposes the second question directly. It adds explicit execution bindings and enforcement requirements while preserving the FIP 0.1 semantic core. Q13 then treated semantic validity, interaction matching, enforcement derivation, target representability, coverage, target-policy non-widening, and freshness as separate security obligations. The campaign discovered genuine failures at several of these boundaries before the frozen Enforcement Candidate satisfied the accepted qualification suite.

The resulting lesson is that governable agent execution requires more than a policy engine or sandbox in isolation. Semantic authority must be explicit, current, bound to the exact interaction, faithfully projected, freshly derived, exactly representable at the selected target, truthfully covered, and prevented from widening during compilation. Target capabilities and policy-prover results do not create semantic authority.

The present FIP 0.2 evidence stops short of end-to-end runtime qualification. Q13 did not execute operational actions, and stale filesystem authority was detected rather than demonstrated to be live-retracted. Runtime retraction, observed TCP and MCP enforcement, exact executable identity, independent credential use, exact model identity, and stronger filesystem object assurance remain future work. Our stance therefore remains falsifiable rather than certifying: the most valuable next step is for independent implementations and adversaries to find an interaction, translation, target mapping, or runtime path that violates the proposed authority boundary.

REFERENCES

- [1] J. H. Saltzer and M. D. Schroeder, "The protection of information in computer systems," *Proc. IEEE*, vol. 63, no. 9, pp. 1278-1308, Sep. 1975.
- [2] J. B. Dennis and E. C. Van Horn, "Programming semantics for multiprogrammed computations," *Commun. ACM*, vol. 9, no. 3, pp. 143-155, Mar. 1966, doi: 10.1145/365230.365252.
- [3] M. Blaze, J. Feigenbaum, and J. Lacy, "Decentralized trust management," in *Proc. 1996 IEEE Symp. Security Privacy*, 1996, pp. 164-173.
- [4] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, and C. E. Youman, "Role-based access control models," *Computer*, vol. 29, no. 2, pp. 38-47, Feb. 1996, doi: 10.1109/2.485845.
- [5] V. C. Hu et al., *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*, NIST SP 800-162, 2014, updated 2019, doi: 10.6028/NIST.SP.800-162.
- [6] OASIS, *eXtensible Access Control Markup Language (XACML) Version 3.0*, OASIS Standard, Jan. 22, 2013.
- [7] R. Iannella and S. Villata, Eds., *ODRL Information Model 2.2*, W3C Recommendation, Feb. 15, 2018.
- [8] L. Moreau and P. Missier, Eds., *PROV-DM: The PROV Data Model*, W3C Recommendation, Apr. 30, 2013.
- [9] T. Finin, R. Fritzson, D. McKay, and R. McEntire, "KQML as an agent communication language," in *Proc. CIKM*, 1994, pp. 456-463, doi: 10.1145/191246.191322.
- [10] Foundation for Intelligent Physical Agents, *FIPA ACL Message Structure Specification*, SC00061, 2002.
- [11] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, *Zero Trust Architecture*, NIST SP 800-207, Aug. 2020, doi: 10.6028/NIST.SP.800-207.
- [12] A. Bansal et al., "Synergistic Simplex: Cooperative runtime assurance for safety-critical autonomous systems," *arXiv:2605.08190*, 2026, doi: 10.48550/arXiv.2605.08190.
- [13] R. Greenblatt, B. Shlegeris, K. Sachan, and F. Roger, "AI Control: Improving safety despite intentional subversion," in *Proc. ICML, PMLR*, vol. 235, 2024, pp. 16295-16336.
- [14] S. Shlomov et al., "Governance by construction for generalist agents," in *Proc. ACM Conf. AI and Agentic Systems*, 2026, pp. 1280-1287, doi: 10.1145/3786335.3813192.
- [15] A. Joshi, T. Finin, K. P. Joshi, and L. Kagal, "Deontic policies for runtime governance of agentic AI systems," *arXiv:2606.19464*, 2026, doi: 10.48550/arXiv.2606.19464.
- [16] G. Besanson, "SARC: A governance-by-architecture framework for agentic AI systems," *arXiv:2605.07728*, 2026, doi: 10.48550/arXiv.2605.07728.
- [17] A. Mazzocchi, "Runtime governance for agentic AI: Action-boundary control with trusted provenance and fail-closed execution," *arXiv:2608.16891*, 2026, doi: 10.48550/arXiv.2608.16891.
- [18] P. Wang, Y. Zhang, R. Zhang, J. Guo, and X. Cheng, "Token-Flow Firewall: Semantic runtime auditing for persistent AI agents," *arXiv:2607.08395*, 2026, doi: 10.48550/arXiv.2607.08395.
- [19] Z. Wang, "CAVA: Canonical Action Verification and Attestation for Runtime Governance of Agentic AI Systems," *arXiv:2607.13716*, 2026, doi: 10.48550/arXiv.2607.13716.
- [20] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo, "MI9 - Agent Intelligence Protocol: Runtime governance for agentic AI systems," *arXiv:2508.03858*, 2025, doi: 10.48550/arXiv.2508.03858.
- [21] Spatial Web Foundation, *The Spatial Web - Universal Domain Graph (UDG) Design Specification*, SWF STD-6:2025, ver. 0.1, 2025.
- [22] Interbilla LLC, "Foundational Interaction Primitives (FIP): specification, reference implementation, conformance vectors, and experimental artifacts," *GitHub*, 2026. [Online]. Available: <https://github.com/interbilla/fip>
- [23] NVIDIA, "OpenShell," *GitHub repository*, 2026. [Online]. Available: <https://github.com/NVIDIA/OpenShell>
- [24] NVIDIA, "OpenShell Policy Schema Reference," *NVIDIA OpenShell Developer Guide*, 2026. [Online]. Available: <https://docs.nvidia.com/openshell/latest/how-it-works/policies/schema>